

ANRH Publications

Audit de dette technique

10 juillet 2026

<https://pub.anrh.fr> (staging)

6 dettes CRITIQUES corrigées

6 SÉCURITÉ + 6 QUALITÉ corrigées — sections 1 à 3

1. Correctifs critiques appliqués

Les points suivants ont été corrigés le 10/07/2026. Ils ne nécessitent plus d'action immédiate.

#1 bin/reset-client-access.php

RÉSOLU

Problème : Mots de passe en dur dans le dépôt.

Action : Mots de passe générés via CLI/env — plus de secrets commités.

#2 tools/migrate-prestashop.php

RÉSOLU

Problème : Script migration accessible via HTTP.

Action : Exécution CLI uniquement (HTTP 403).

#3 inc/b2b/tools.php

RÉSOLU

Problème : Export CSV panier sans contrôle prix B2B.

Action : Export réservé aux clients connectés et approuvés.

#4 inc/b2b/tools.php

RÉSOLU

Problème : Compateur AJAX sans nonce.

Action : check_ajax_referer + nonce JS ajoutés.

#5 .github/workflows/

RÉSOLU

Problème : Déploiement sans validation préalable.

Action : Job valide (lint PHP, grep secrets) avant FTP.

#6 deploy-staging.yml

RÉSOLU

Problème : Déploiement non vérifié après envoi.

Action : Smoke test HTTP post-deploy + exclusion bin/tools du bundle.

2. Sécurité applicative — corrigée

Les 6 points de la section « Sécurité applicative (restant) » ont été corrigés le 10/07/2026.

#7 inc/b2b/pricing.php

RÉSOLU

Problème : Calcul prix HT sans gate centralisé.

Action : anrhpublish_price_visible_context() intégré dans get_unit_price_ht().

#8 inc/b2b/client-pro.php

RÉSOLU

Problème : Compte sans meta = approuvé par défaut.

Action : Statut pending par défaut + migration comptes existants.

#9 inc/contact-form.php

RÉSOLU

Problème : Formulaire devis sans rate limiting ni CAPTCHA.

Action : Throttling IP + captcha arithmétique.

#10 inc/newsletter.php

RÉSOLU

Problème : Inscription AJAX sans limitation.

Action : Rate limit par IP et par e-mail.

#11 inc/b2b/quotes.php

RÉSOLU

Problème : PDF devis : capability edit_posts trop large.

Action : Accès restreint via edit_post sur le devis.

#12 inc/gdpr.php

RÉSOLU

Problème : Bandeau cookies sans blocage scripts.

Action : CMP minimal : blocage scripts analytics + activation au consentement.

3. Qualité de code et architecture — corrigée

Les 6 points de la section « Qualité de code et architecture » ont été corrigés le 10/07/2026.

#13 tests/ + composer.json

RÉSOLU

Problème : Aucun test automatisé.

Action : PHPUnit : auth B2B, panier devis, PDF devis (CI).

#14 assets/js/src/ + Vite

RÉSOLU

Problème : Monolithe main.js 2700+ lignes.

Action : 14 modules ES + build Vite (fallback Python).

#15 functions.php

RÉSOLU

Problème : 10+ CSS sur toutes les pages.

Action : Enqueue conditionnel : vitrine, pages, B2B par contexte.

#16 inc/catalogue-search.php

RÉSOLU

Problème : Requêtes illimitées par recherche.

Action : Limite 500 résultats, requête catégories groupée, cache transient.

#17 inc/product-colors/

RÉSOLU

Problème : God-module 1200+ lignes.

Action : Scindé en taxonomy, admin-term, admin-product, frontend.

#18 inc/demo-data.php

RÉSOLU

Problème : Données démo au switch thème.

Action : Désactivé hors local/development (WP_ENVIRONMENT_TYPE).

4. Déploiement et infrastructure

#1 FTP OVH

Élevé

Problème : Protocole FTP en clair, déploiement non atomique.

Action : SFTP si disponible ; healthcheck (fait).

#2 deploy-staging.yml

Élevé

Problème : Fichiers orphelins non supprimés sur le serveur.

Action : Sync miroir ou nettoyage ciblé.

#3 staging-health.php

Moyen

Problème : Script diagnostic en webroot.

Action : Retirer après validation.

#4 export-staging-db.ps1

Moyen

Problème : Export DB manuel Windows uniquement.

Action : wp-cli search-replace cross-platform.

#5 README.md

Faible

Problème : Documentation partiellement obsolète.

Action : Aligner sur WP 7.0 et scope deploy.

5. Configuration et WordPress core

#6 wp-config.template.php

Élevé

Problème : Sels WordPress statiques dans le repo.

Action : Sels uniques par environnement via secrets.

#7 .gitignore

Élevé

Problème : WordPress core versionné (~5500 fichiers).

Action : Déployer le core via Composer/wp-cli.

#8 wp-config.template.php

Moyen

Problème : Pas de DISALLOW_FILE_EDIT, FORCE_SSL_ADMIN.

Action : Durcissement production.

#9 plugins/

Faible

Problème : Akismet inutile, UpdraftPlus lourd.

Action : Nettoyer les plugins.

6. Plan de remédiation

P1 — Important

- Sels WordPress uniques par environnement
- Export DB avec wp search-replace (serialized-safe)

P2 — Amélioration

- Retirer staging-health du deploy automatique
- Réduire le scope git (core WP hors repo)
- Étendre la couverture PHPUnit (intégration WP)

P3 — Confort

- Audit accessibilité WCAG 2.1 AA
- Internationalisation complète (.pot)
- Stratégie production documentée